Segurança de Dados
Assignment 1

Hugo Soares

24 de setembro de 2026

Questão 1

Foi escolhido o Mozilla Firefox, um navegador utilizado diariamente para aceder a serviços Web. A pesquisa incidiu sobre CVEs publicadas nos últimos doze meses relativamente à data deste relatório. As três vulnerabilidades selecionadas afetam diretamente o Firefox e foram corrigidas na versão 152.

CVE	**Descrição**	**CVSS e interpretação**	**CWE / exploit**
CVE-2026-12300	Falha de segurança de memória no Firefox, corrigida na versão 152. A exploração poderia permitir a leitura de dados fora dos limites esperados do buffer, comprometendo a confidencialidade do processo [15].	5.3 Médio (CVSS 3.1): exploração remota sem autenticação nem interação, com impacto limitado na confidencialidade.	CWE-119; exploit público não confirmado nas fontes consultadas.
CVE-2026-12301	Outra falha de segurança de memória no Firefox, também corrigida na versão 152. Erros deste tipo podem provocar leitura ou corrupção de memória e, dependendo do contexto, levar a divulgação de informação ou execução de código [16].	5.3 Médio (CVSS 3.1): ataque remoto com impacto baixo na confidencialidade e sem impacto direto registado na integridade ou disponibilidade.	CWE-119; exploit público não confirmado nas fontes consultadas.
CVE-2026-12303	O componente Graphics: WebGPU tinha condições de fronteira incorretas, permitindo uma leitura fora dos limites e possível divulgação de informação através de conteúdo Web especialmente preparado [17].	4.3 Médio (CVSS 3.1): requer interação do utilizador e afeta principalmente a confidencialidade.	CWE-125; exploit público não confirmado nas fontes consultadas.

As pontuações, classificações e CWEs foram consultadas nos registos oficiais CVE. "Exploit: Não confirmado" significa que não foi encontrada uma prova de conceito pública nas fontes

consultadas; não significa que a vulnerabilidade seja inexequível. A mitigação comum é atualizar o Firefox para a versão 152 ou posterior e manter as atualizações automáticas ativas.

Análise aprofundada da CVE-2026-12303

Impacto em produção. Um utilizador que abrisse uma página Web maliciosa poderia expor informação presente no processo do Firefox através de uma leitura fora dos limites no componente WebGPU. O impacto principal é a perda de confidencialidade; em certos cenários, uma falha de memória semelhante poderia também ser encadeada com outra vulnerabilidade para obter execução de código.

Sistemas expostos. Estão expostos computadores que executem versões do Firefox anteriores à 152 e tenham o WebGPU disponível. O risco é relevante em estações de trabalho que naveguem por páginas não confiáveis, executem aplicações Web com gráficos 3D ou processem publicidade e conteúdos incorporados de terceiros.

Patch e prevenção. A correção está incluída no Firefox 152. Deve-se atualizar o navegador através do mecanismo normal de atualização, confirmar a versão instalada e reiniciar o Firefox quando solicitado. Como medidas complementares, devem manter-se ativos o isolamento de processos, a proteção contra sites maliciosos e as atualizações automáticas; em ambientes que não possam atualizar imediatamente, pode-se desativar temporariamente o WebGPU através das políticas de gestão do Firefox, tendo em conta a perda de funcionalidade gráfica.

Questão 2

Num pagamento online participam o cliente, o operador do cartão e o vendedor. O sistema deve garantir:

- **Confidencialidade**: número do cartão, credenciais, montante e dados pessoais não devem ser divulgados a terceiros.
- **Integridade**: identidade do vendedor, montante, moeda e destino do pagamento não podem ser alterados sem deteção.
- **Autenticidade**: o cliente deve autenticar-se perante o operador e o vendedor deve ser autenticado pelo cliente; o operador deve confirmar a autorização da transação.
- **Não repúdio e responsabilização**: devem existir registos, identificadores e provas suficientes para atribuir a operação às entidades envolvidas.
- **Disponibilidade e frescura**: o serviço deve resistir a indisponibilidade e replay de pedidos antigos.

As principais classes de ameaça são interceção e man-in-the-middle, phishing e roubo de credenciais, malware no dispositivo do cliente, fraude por replay ou manipulação de mensagens, roubo de dados no vendedor ou no operador, abuso de privilégios internos, comprometimento de APIs e ataques de negação de serviço. TLS, autenticação multifator, tokenização, 3-D Secure, assinaturas/MACs, limites de operação, deteção de fraude e logs imutáveis ajudam a reduzir esses riscos.

Questão 3

As quatro CVEs mostram que a segurança de um sistema criptográfico depende tanto da sua implementação como do algoritmo utilizado. Cada caso ilustra uma falha diferente.

- **CVE-2025-30406 – Gladinet CentreStack**: a aplicação utilizava uma `machineKey` criptográfica hardcoded. Quem conhecesse essa chave podia criar um payload de desserialização malicioso e obter execução remota de código no servidor. O problema corresponde principalmente a `CWE-321` (uso de chave criptográfica hardcoded) e `CWE-798` (credencial

hardcoded). É uma falha crítica, explorada na prática, e deve ser mitigada atualizando o CentreStack para uma versão corrigida e removendo ou regenerando a chave conforme as instruções do fabricante [18].

- **CVE-2025-52374 – hMailServer**: o programa usava uma chave criptográfica hardcoded para proteger palavras-passe guardadas no ficheiro de configuração do `hMailAdmin`. Um atacante com acesso a esse ficheiro podia desencriptar as credenciais e usá-las para aceder a outras consolas de administração. A CWE associada é a `CWE-321`. A correção exige atualizar para uma versão suportada pelo fabricante; também é necessário restringir o acesso ao ficheiro, alterar as palavras-passe potencialmente expostas e evitar reutilização de credenciais [19].
- **CVE-2025-54887 – Ruby `jwe`**: nas versões até 1.1.0, as tags de autenticação de JWE podiam ser obtidas por brute force. Isso permitia modificar mensagens, criar JWEs arbitrários e, em certas condições, recuperar a chave interna GHASH, comprometendo confidencialidade e integridade. A falha é classificada como `CWE-354` (validação incorreta do valor de integridade). A versão 1.1.1 corrige o problema, mas como as chaves podem já ter sido expostas, é necessário atualizá-la e rodar as chaves de encriptação [20].
- **CVE-2025-3501 – Keycloak**: quando a política de verificação era configurada como `ALL`, o Keycloak podia ignorar a validação do certificado no trust store. Assim, uma ligação TLS podia aceitar um certificado que não devia ser considerado confiável, quebrando a autenticação do servidor e permitindo um ataque man-in-the-middle. A CWE associada é a `CWE-297`, relacionada com validação incorreta de certificados. A mitigação consiste em aplicar a atualização do Keycloak indicada pelo fabricante e rever as políticas de trust store e de verificação de certificados [21].

Em conjunto, os casos revelam fontes recorrentes de vulnerabilidade: segredos incorporados no código, uso inseguro de primitivas criptográficas, validação incompleta de integridade e configuração incorreta de autenticação. As CWEs mais relevantes são, respetivamente, `CWE-321`, `CWE-798`, `CWE-354` e `CWE-297`. Portanto, a criptografia não substitui gestão adequada de chaves, validação rigorosa, configuração segura, atualizações e revisão de código.

Questão 4

Considera-se uma VPN baseada em WireGuard entre o computador do trabalhador remoto e a rede corporativa. Deve garantir confidencialidade e integridade dos pacotes, autenticação mútua dos peers, controlo de acesso à rede interna, proteção contra replay, perfect forward secrecy quando possível e disponibilidade suficiente para o trabalho remoto. Também deve impedir que um atacante se faça passar pelo gateway ou pelo trabalhador.

O WireGuard usa pares de chaves públicas/privadas Curve25519 para autenticar peers e estabelecer chaves efémeras através de um handshake baseado em Noise. Deriva chaves de sessão com uma função de derivação baseada em HKDF e protege os dados com ChaCha20-Poly1305, que fornece confidencialidade e autenticação. Nonces, contadores e mecanismos anti-replay impedem a reutilização de pacotes. A distribuição da chave pública do gateway e a configuração de allowed IPs são essenciais para associar cada peer à rede autorizada.

As ameaças incluem roubo da chave privada do cliente, comprometimento do gateway, configuração excessivamente permissiva, endpoint infetado, phishing, ataque de negação de serviço, bloqueio ou interferência na rede, replay, fuga de DNS e exposição de tráfego antes de entrar ou depois de sair da VPN. A mitigação exige armazenamento protegido de chaves, rotação e revogação de peers, MFA no acesso complementar, atualizações, segmentação, regras de firewall, DNS seguro, logs e monitorização.

Questão 5

Foi selecionada a implementação OpenSSH, uma implementação amplamente usada do protocolo SSH para administração remota, transferência de ficheiros e túneis seguros. As três vulnerabilidades seguintes foram publicadas nos últimos doze meses relativamente à data deste relatório.

CVE	Descrição	CVSS e interpretação	CWE / exploit
CVE-2026-35414	O OpenSSH anterior à versão 10.3 tratava incorretamente a opção `principals` de `authorized_keys` em cenários com listas de principals e uma Certificate Authority. Um atacante podia conseguir autenticação ou autorização diferente da pretendida [12].	8.1 Alto (métrica CNA; o NVD apresenta 4.2): pode afetar confidencialidade, integridade e disponibilidade, embora exija condições difíceis.	CWE-670; exploit público não confirmado nas fontes consultadas.
CVE-2026-55654	Durante a limpeza dos indicadores de autenticação GSSAPI, uma terminação nula em falta podia causar uma leitura fora dos limites. Em servidores configurados com GSSAPI e Kerberos, um atacante remoto podia provocar a interrupção do caminho de autenticação e causar negação de serviço [13].	7.7 Alto: ataque remoto sem autenticação, com impacto na disponibilidade do serviço.	CWE-125; exploit público não confirmado nas fontes consultadas.
CVE-2026-60002	O cliente SSH podia sofrer um use-after-free quando o servidor alterava a sua host key durante uma renegociação de chaves. A exploração podia comprometer a sessão e, conforme a métrica utilizada, afetar confidencialidade, integridade e disponibilidade [14].	9.4 Crítico (métrica CNA; o NVD apresenta 7.7): ataque remoto sem autenticação durante o rekeying.	CWE-416; exploit público não confirmado nas fontes consultadas.

As versões afetadas são OpenSSH anteriores a 10.3 para as CVE-2026-35414 e CVE-2026-55654, e anteriores a 10.4 para a CVE-2026-60002. As correções devem ser instaladas através da versão oficial correspondente ou do pacote de segurança da distribuição Linux. Estes casos afetam mecanismos de autenticação, certificados, GSSAPI/Kerberos e renegociação de chaves, mostrando que a segurança de uma implementação depende tanto da criptografia como da validação e gestão do protocolo.

Análise aprofundada da CVE-2026-60002

Impacto em produção. Durante o rekeying, o cliente SSH podia aceder a memória já libertada quando o servidor alterava a sua host key. Um atacante capaz de controlar ou comprometer o servidor poderia explorar o comportamento para causar corrupção de memória, terminar o cliente ou, em determinadas condições, obter execução de código. Isso compromete a confidencialidade e a integridade das sessões SSH.

Patch e aplicação. Deve-se atualizar o cliente OpenSSH para a versão 10.4 ou posterior, ou instalar o pacote corrigido fornecido pelo sistema operativo. Depois da atualização, deve-se confirmar a versão, testar a ligação e rever os logs de autenticação. Enquanto a atualização não

for possível, deve-se evitar ligações a servidores não confiáveis, verificar as host keys por um canal independente e limitar o acesso SSH através de bastion hosts e regras de firewall.

Cenários mais expostos e prevenção. O risco é maior em clientes SSH usados para administração remota, automação e pipelines que mantenham sessões longas e permitam renegociação de chaves. A atualização é a medida principal; adicionalmente, devem ser verificadas as chaves dos hosts, restringidos os servidores autorizados, aplicados privilégios mínimos e monitorizados reinícios inesperados ou falhas durante autenticação e rekeying.

Referências

[1] CVE Program, "CVE-2026-8913." https://www.cve.org/CVERecord?id=CVE-2026-8913

[2] TP-Link, "Archer MR600 V5 security advisory." https://www.tp-link.com/us/support/faq/5122/

[3] CVE Program, "CVE-2026-72603." https://www.cve.org/CVERecord?id=CVE-2026-72603

[4] wg-easy, "WireGuard Easy project repository." https://github.com/wg-easy/wg-easy

[5] CVE Program, "CVE-2026-58085." https://www.cve.org/CVERecord?id=CVE-2026-58085

[6] FreeBSD, "FreeBSD-SA-26:52.if_wg." https://security.freebsd.org/advisories/FreeBSD-SA-26:52.if_wg.asc

[7] NVD, "CVE-2025-26465." https://nvd.nist.gov/vuln/detail/CVE-2025-26465

[8] Qualys, "OpenSSH MITM and DoS vulnerabilities." https://www.qualys.com/2025/02/18/openssh-mitm-dos.txt

[9] NVD, "CVE-2025-26466." https://nvd.nist.gov/vuln/detail/CVE-2025-26466

[10] NVD, "CVE-2025-32728." https://nvd.nist.gov/vuln/detail/CVE-2025-32728

[11] OpenSSH, "Security." https://www.openssh.org/security.html

[12] NVD, "CVE-2026-35414." https://nvd.nist.gov/vuln/detail/CVE-2026-35414

[13] NVD, "CVE-2026-55654." https://nvd.nist.gov/vuln/detail/CVE-2026-55654

[14] NVD, "CVE-2026-60002." https://nvd.nist.gov/vuln/detail/CVE-2026-60002

[15] NVD, "CVE-2026-12300." https://nvd.nist.gov/vuln/detail/CVE-2026-12300

[16] NVD, "CVE-2026-12301." https://nvd.nist.gov/vuln/detail/CVE-2026-12301

[17] NVD, "CVE-2026-12303." https://nvd.nist.gov/vuln/detail/CVE-2026-12303

[18] NVD, "CVE-2025-30406." https://nvd.nist.gov/vuln/detail/CVE-2025-30406

[19] NVD, "CVE-2025-52374." https://nvd.nist.gov/vuln/detail/CVE-2025-52374

[20] NVD, "CVE-2025-54887." https://nvd.nist.gov/vuln/detail/CVE-2025-54887

[21] NVD, "CVE-2025-3501." https://nvd.nist.gov/vuln/detail/CVE-2025-3501